
SMART MANAGER ERP · SECURITY RECONCILIATION

Supabase Schema Synchronization & Auth Identity Snapshot

Evidence-led alignment of repository migrations, live database controls, and fail-closed authentication hydration.



Implementation review · 23 August 2026

Prepared for engineering, security, and platform operations

One evidence chain, not a blind replay

The synchronization pass aligns declared contracts with the verified live catalog, then validates the application path without resetting production or changing behavior by assumption.

01

Repository

Versioned migrations, AuthProvider contracts, tests, and schema references define the intended change.

02

Supabase

→ Live tables, keys, policies, indexes, triggers, functions, storage, and migration history are inspected first.

03

Application

→ Backend, frontend, build, focused browser tests, and protected auth transitions are checked after DDL.

Safety boundary: apply only verified additive changes; preserve existing data, RLS, and module behavior.

Live schema is present; history has drift

The connected project contains the declared application tables. The reconciliation risk is not missing core tables—it is the mismatch between historical migration names and the current source tree.

518	279	0	0
public tables inventoried	tables declared by local migrations	local-declared tables missing live	public tables with RLS disabled

Interpretation

Do not replay the repository directory blindly. The live ledger includes historical aliases and earlier module migrations that are not one-to-one with the current filenames.

- Inspect** catalog, ledger, policies, and dependencies
- Compare** normalized object contracts
- Apply** only verified additive migrations
- Verify** database and application behavior

Source: Supabase connector list_tables, list_migrations, and catalog queries; reconciliation run 23 Aug 2026.

Database controls remain enabled

No destructive reset, manual ledger edit, or blanket RLS change was performed. Existing security and integrity measures were preserved during synchronization.



STORAGE BUCKETS PRESENT

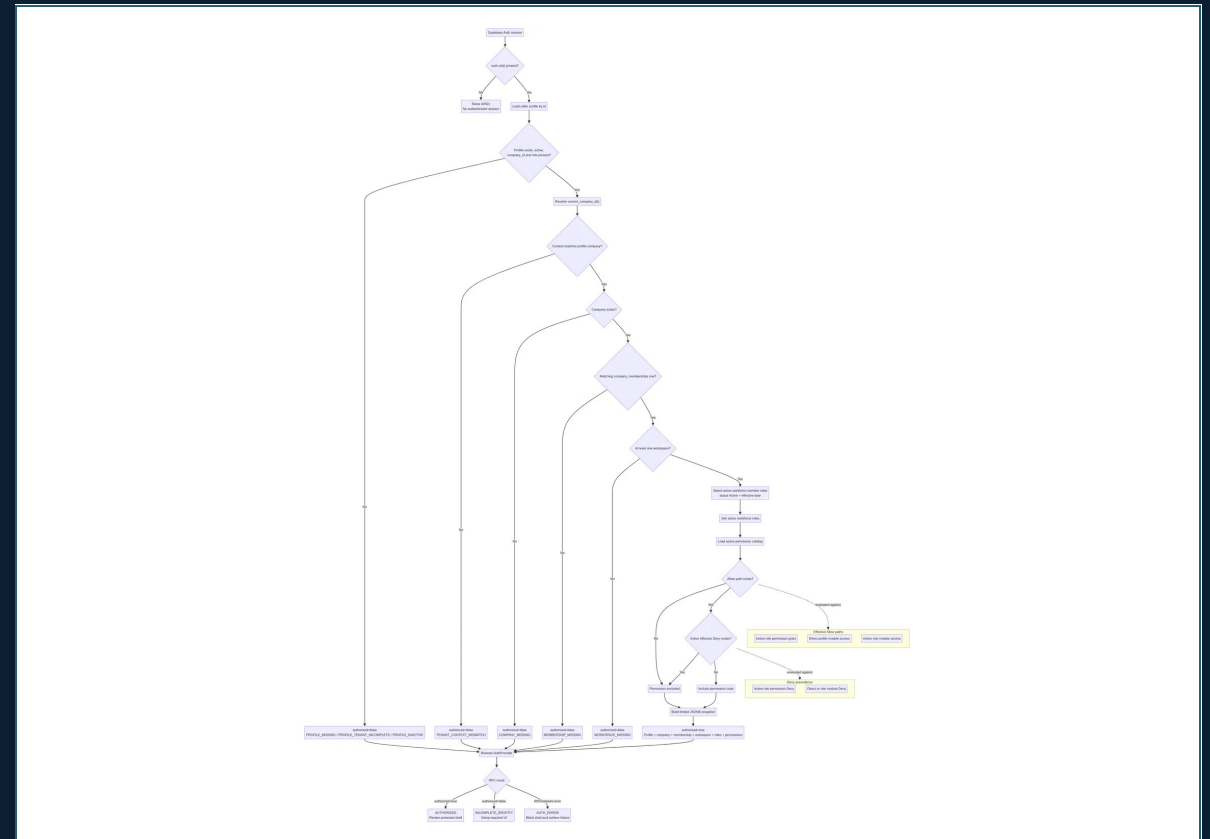
- avatars**
PUBLIC • 2 MIB LIMIT
- company-logos**
PUBLIC • 2 MIB LIMIT
- documents**
PRIVATE • 25 MIB LIMIT

Source: Supabase connector catalog inventory, 23 Aug 2026.

One server snapshot closes the tenant boundary

`public.auth_identity_snapshot()` is a new additive RPC that returns limited identity metadata instead of exposing browser-side table joins as authority.

- Requires an **auth.uid()** and raises SQLSTATE 42501 when absent.
- Requires **active** and matching company context.
- Requires an **company, membership, workspace.** existing and
- Fails closed if any condition is not met, preventing unauthorized access.



Effective permissions are evaluated in PostgreSQL

The snapshot RPC calculates effective permissions server-side, ensuring consistent enforcement across the application without relying on client-side joins.

Active Workforce Roles

Active workforce member roles are strictly filtered by their current status and effective date windows, ensuring only currently valid assignments are considered.

Deny Precedence

Security is fail-closed. Active, time-valid Deny grants strictly override any Allow grants for the same permission, preventing accidental escalation.

Allow Paths

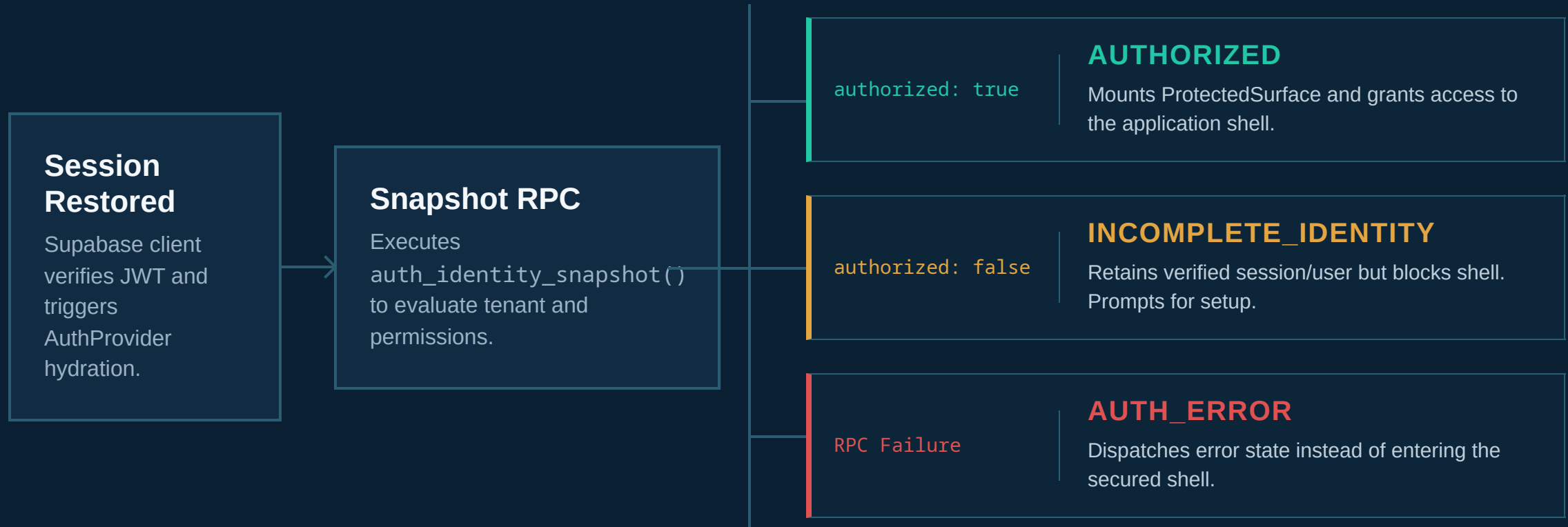
The permission catalog is limited to active tenant permissions. Access can be granted through explicit role grants or direct profile/role module access.

Legacy-Role Containment

Legacy profile role strings are returned for display compatibility only. They are intentionally excluded from the permission calculation and cannot silently grant access.

Frontend hydration now fails closed

The AuthProvider maps the server snapshot directly into explicit reducer states, ensuring the protected shell never mounts with an incomplete identity.



Verification evidence is layered

Validation spans database privileges, unit contracts, and production builds, ensuring the identity snapshot integrates safely across the stack.

✓ SQL Privilege & Invocation Checks

Security definer enabled; anon execution revoked; authenticated execution granted. Unauthenticated RPC invocation correctly raises SQLSTATE 42501.

✓ Focused Auth Contracts

3 files and 10 tests passed, verifying the fail-closed state machine and snapshot hydration logic.

✓ Full Vitest Suite

204 files and 835 tests passed (with 5 skipped), confirming no regressions in adjacent modules.

✓ Production Build

Completed successfully through the Vercel-compatible path, ensuring deployment readiness.

Advisor findings require targeted follow-up

Supabase security and performance advisors identified historical configuration gaps. These require individual workload and product-intent review rather than automated blanket migrations.

SECURITY

117 WARNINGS

Authenticated security-definer calls	110
Anonymous security-definer calls	6
Breached-password protection disabled	1

PERFORMANCE

855 FINDINGS

Unindexed foreign keys	632
Multiple permissive policies	152
Unused indexes	61
Auth RLS init-plan warnings	10

Why blanket changes were avoided

Applying hundreds of indexes simultaneously creates severe write-lock and maintenance overhead. Revoking anonymous RPCs without reviewing intended public workflows (e.g., booking/seat availability) risks breaking legacy modules. Remediation must be targeted and evidence-based.

Safe next sequence

The schema synchronization is additive and evidenced. The remaining work focuses on fixture-backed deployed E2E and targeted advisor remediation—not an unsafe global rewrite.

1. Deployed E2E Validation

STEP 1.1

Provision isolated non-production Auth users, tenants, memberships, workspaces, roles, and markers.

STEP 1.2

Run the guarded remote Playwright suite against an approved preview URL.

2. Targeted Advisor Remediation

STEP 2.1

Review six anonymous security-definer routines one by one before changing privileges.

STEP 2.2

Prioritize high-value FK indexes and policy simplification from measured workloads.

3. Migration Reconciliation

STEP 3.1

Reconcile historical migration-source drift through a deliberate snapshot process, not blind replay.